NIVELAMIENTO TÉCNICO

SESSION 05: SSRF & XXE PRE-REQUISITES

Infraestructura, Redes y Formatos de Datos

Bloque 1: Protocolos & Redes

Entendiendo el contexto donde se ejecutan los ataques SSRF.

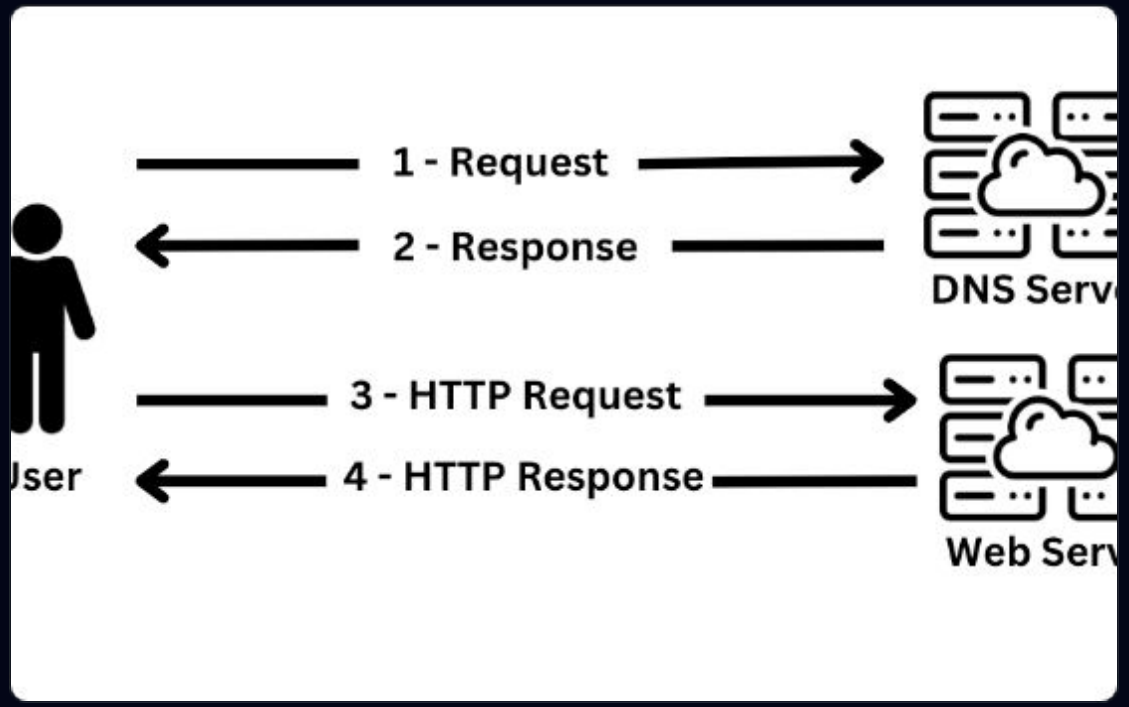
Anatomía de la Petición HTTP

Para manipular I/O, debemos conocer la estructura de transporte.

```
POST /api/v1/user HTTP/1.1
Host: qbit.io
Content-Type: application/xml

...
```

Clave: El SSRF inyecta una URL maliciosa en parámetros que el servidor procesa.



Desconstrucción de una URL

Un SSRF exitoso depende de manipular las partes de la URL para engañar al servidor.

- **Scheme:** Protocolo (http, https, file, gopher).
- **Host:** Dirección IP o Dominio.
- **Port:** Puerto del servicio (80, 443, 6379).
- **Path:** Ruta al recurso interno.

- **Scheme:** This indicates the protocol to be used by the server, like '*https*' for secure browsing.
- **Host:** This identifies the server that's hosting the web resource, like '*www.example.com*'.
- **Subdomain:** This is a subdivision of the main domain, often used to organize content or services, like 'blog' in '*blog.example.com*'.
- **Second-Level Domain:** The name of a website that signals its brand identity, for example, 'mlb' in '*mlb.com*'.
- **Top-Level Domain:** This specifies the type of entity your organization registers as, like '.com' for commercial entities or '.edu' for academic institutions.
- **Subdirectory:** This is a subfolder that gives an indication of the specific webpage section, such as 'hats' in '*https://shop.yourstore.com/hats*'.
- **Path:** This specifies the location of a specific resource on the server after the domain and any subdomain(s), such as '*/products/software/index.html*' in '*https://www.example.com/products/software/index.html*'.
- **Query String:** This is a sequence of non-hierarchical data (parameters) passed to the server for additional instructions or data processing.

Rangos de IP Privados (RFC 1918)

Clase A

10.0.0.0 — 10.255.255.255

Común en redes corporativas masivas y AWS VPCs.

Clase B

172.16.0.0 — 172.31.255.255

Usualmente reservado para subredes de servidores específicos.

Clase C

192.168.0.0 — 192.168.255.255

Estándar para redes domésticas y oficinas pequeñas.

El SSRF busca saltar del IP Público al IP Privado.

Localhost & Trust

127.0.0.1

Interface de Loopback

Confianza Implícita

Muchos servidores confían en peticiones que vienen de sí mismos (localhost).

Si el servidor tiene un panel de control en el puerto 8080 que no pide contraseña si la IP de origen es 127.0.0.1, el SSRF permite comprometerlo totalmente.

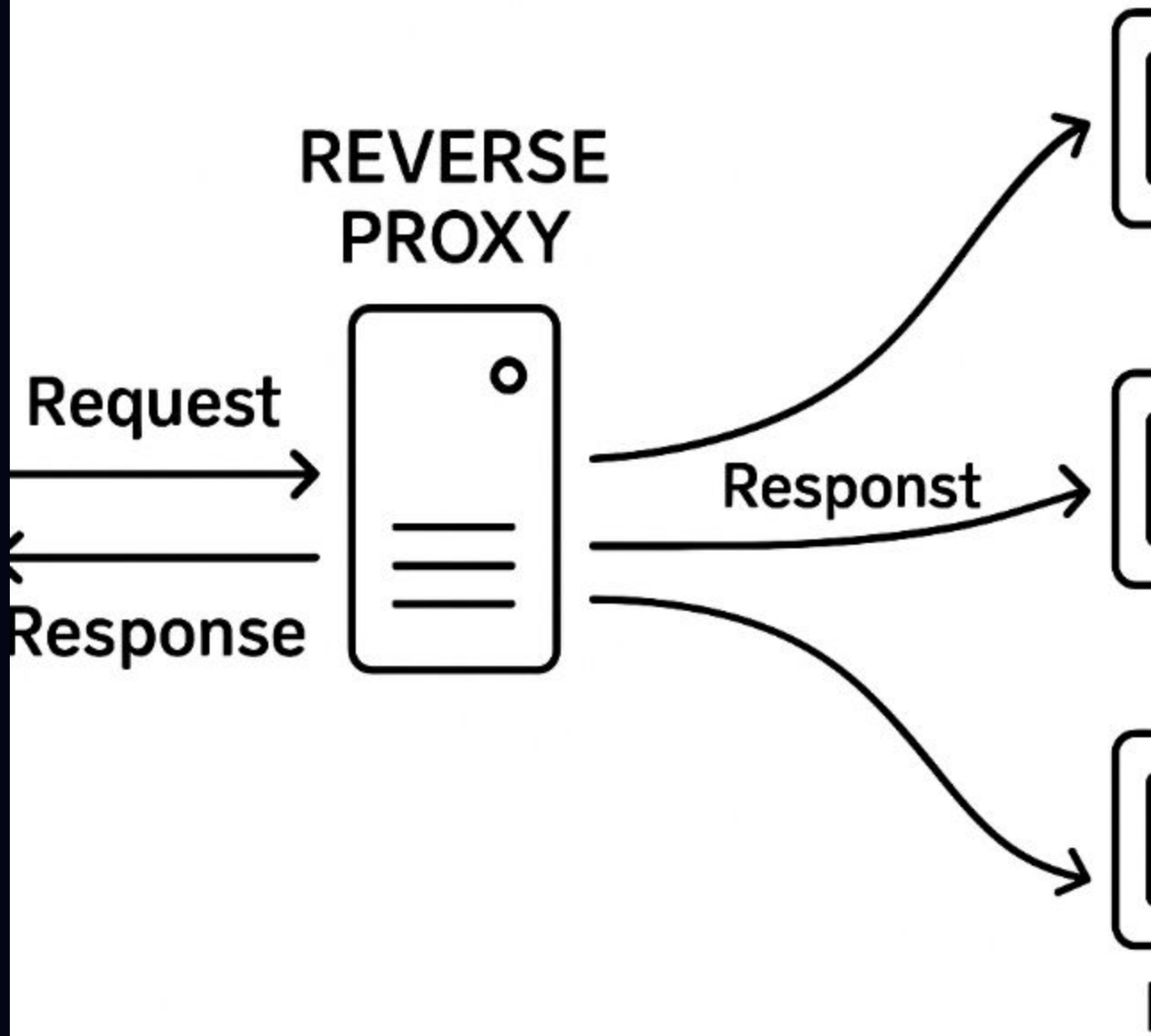
Puertos & Servicios Críticos

Puerto	Servicio Común	Interés del Auditor (SSRF)
3306	MySQL	Extracción de credenciales y datos.
6379	Redis	Ejecución de comandos y cache poisoning.
11211	Memcached	Robo de sesiones y datos en memoria.
8080 / 8443	Paneles Admin	Consolas de gestión sin autenticación interna.

Proxies & Gateways

En infraestructuras modernas, un Reverse Proxy (Nginx, F5) recibe la petición y la reenvía a un App Server interno.

SSRF es el ataque donde forzamos al App Server a actuar como si fuera él mismo el origen de una nueva petición hacia otros servidores internos (Back-office, DBs).



Bloque 2: Formatos & Datos

Pre-requisitos para entender la inyección de entidades externas (XXE).

Serialización: XML vs JSON

JSON (Moderno)

Formato ligero basado en texto. Solo transporta datos. No tiene lógica interna compleja.

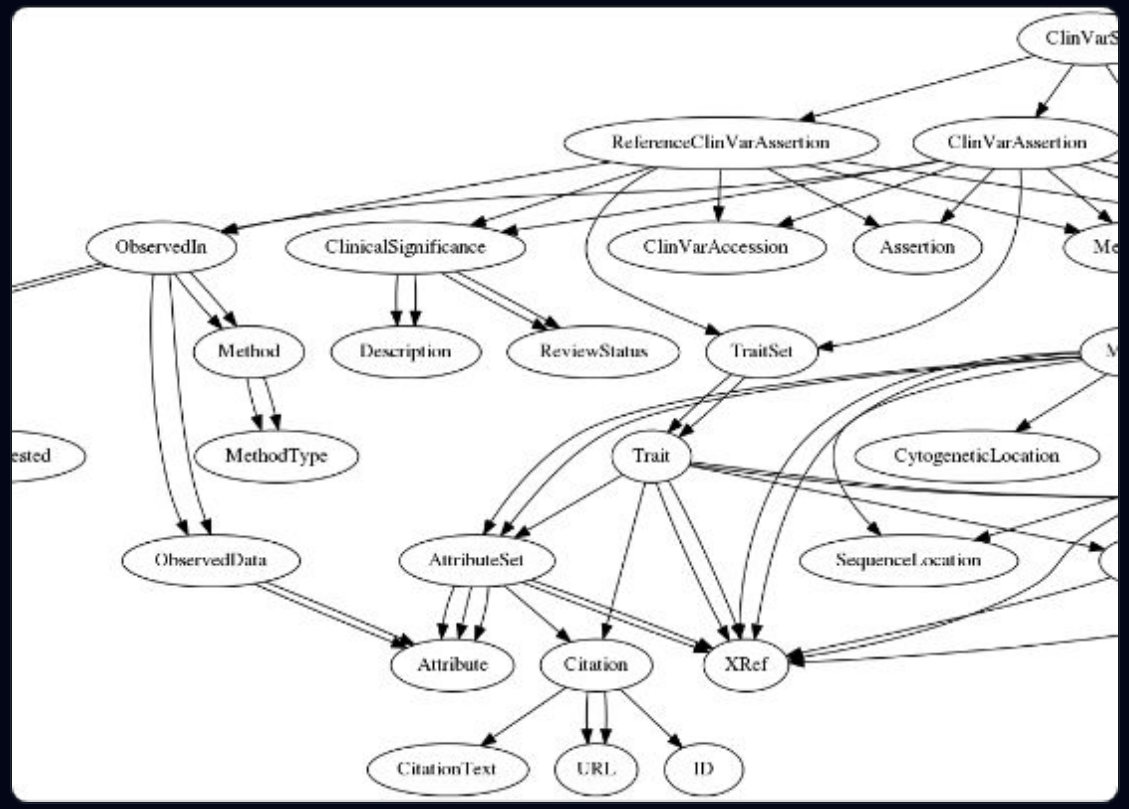
```
{"user": "admin"}
```

XML (Potente)

Lenguaje de marcado. Incluye lógica de definición (DTD) y entidades. **Vulnerable por diseño** si no se asegura el parser.

```
admin
```

Sintaxis Básica de XML



XML organiza datos en una estructura de árbol.

- **Prolog:** Declaración inicial (versión, encoding).
- **Root Element:** El contenedor principal.
- **Tags:** Etiquetas de apertura y cierre.
- **Attributes:** Metadatos dentro de los tags.

Document Type Definition (DTD)

Definición: El DTD define la estructura legal (gramática) de un documento XML.

Declaración: Se define mediante la etiqueta .

Puente al XXE: Es dentro del DTD donde podemos declarar **Entidades**, que son como "variables" para el documento.

```
]>
```

Entidades: Internas vs Externas

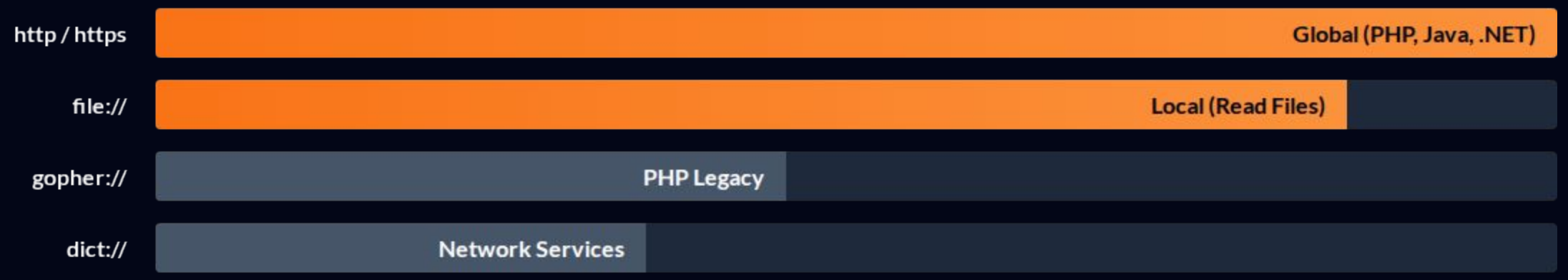
Entidad Interna

Simplemente un atajo de texto dentro del mismo archivo.

Entidad Externa (XXE)

Carga contenido desde una fuente externa usando **SYSTEM**.

Availability of URI Schemes



Dependiendo del lenguaje de programación del backend, tendremos acceso a diferentes esquemas para exfiltrar datos o atacar la red.

¿DUDAS?

NIVELAMIENTO COMPLETADO.

Preparados para la fase de explotación: SSRF & XXE Labs.

github.com/djotahub // vanguardiun.academy